

INFORME EJECUTIVO DE RIESGOS DE CIBERSEGURIDAD

Destinatarios: Directorio y Gerencia General

Entidad: Clínica Médica Privada

Fecha: Agosto 2026

Responsable: Área de Seguridad de la Información

1. Resumen Ejecutivo y Contexto de Amenazas

A raíz de la auditoría externa, se llevó a cabo un relevamiento exhaustivo sobre la infraestructura que soporta la atención de 800 pacientes diarios y 120 colaboradores.

A modo de analogía conceptual, las amenazas externas operan bajo la dinámica del **lobo feroz acechando a Caperucita Roja**: los vectores de ataque (como el ransomware y el phishing masivo) aprovechan los canales de comunicación cotidianos y la aparente inocencia de los usuarios finales en el trayecto digital para engañarlos y vulnerar el activo más valioso de la clínica: los datos médicos.

2. Top 5 de Riesgos Prioritarios

ID	Riesgo Identificado	Nivel	Impacto Operativo y Asistencial
R1	Ransomware en Servidores de HCE	CRÍTICO	Cifrado masivo, cese de cirugías y consultas
R2	Filtración por Phishing Masivo	CRÍTICO	Robo de credenciales y fuga de diagnósticos
R3	Falla en Facturación con Obras Sociales	MEDIO-ALTO	Interrupción en cobros y cuello de botella
R4	Terminales Desatendidas en Consultorios	MEDIO	Exposición visual de historias clínicas
R5	Corte de Enlace Principal (Fibra Óptica)	MEDIO	Pérdida de validación de credenciales online

3. Plan de Tratamiento: Estrategia de Defensa en Capas

Para mitigar la exposición crítica, el plan de tratamiento adopta la analogía de **los 3 cerditos como modelo de capas de defensa**:

- Capa 1 (Paja - Perímetro básico):** Filtros antispam y antivirus básicos, insuficientes por sí

solos ante ataques directos.

- **Capa 2 (Madera - Controles intermedios):** Doble factor de autenticación (MFA) y políticas estrictas de puestos de trabajo.
- **Capa 3 (Ladrillo - Resiliencia sólida):** Almacenamiento inmutable WORM aislado, EDR con contención automática y contingencia offline asíncrona.

Proyectos y Presupuesto

1. **Plan R1 - Resiliencia HCE (Ladrillo):** Backups WORM + EDR. Presupuesto: **USD 4.500** (Plazo: 30 días).
2. **Plan R2 - Control de Acceso y MFA (Madera):** Doble factor para 120 usuarios y concientización. Presupuesto: **USD 1.800** (Plazo: 15 días).
3. **Plan R3 - Contingencia Transaccional:** Caché offline para obras sociales. Presupuesto: **USD 2.200** (Plazo: 45 días).

Inversión Total Requerida: USD 8.500

4. Recomendaciones Prioritarias para la Dirección

1. **Aprobación presupuestaria inmediata** de las soluciones de arquitectura sólida (Planes R1 y R2).
2. **Seguridad Física e Infraestructura Crítica:** Como recomendación prioritaria, los centros de datos y salas de servidores nunca deben ubicarse al lado de cocinas ni debajo de piletas o cañerías principales de agua, debido al riesgo inminente de incendio e inundación respectivamente.
3. **Mesa de Gobierno de Riesgos:** Implementar revisiones trimestrales con reporte directo a Gerencia.